AAROHAN BANK LTD.

Cybersecurity Governance, Risk & Compliance (GRC) – Portfolio Project

Platform: ServiceNow Developer Instance | **Project type:** Self-directed simulated case study | **Assessment date:** 30 October 2026

Important project disclaimer

This is a fictional learning and portfolio project. Aarohan Bank Ltd. is a fictional organization, and all risks, sample account details, control-test outcomes, and remediation examples are simulated. No real bank environment, customer data, or production security controls were accessed or audited.

Project Overview

This project demonstrates a practical, entry-level GRC workflow using a ServiceNow Developer Instance. A cybersecurity risk register was created for a fictional banking organization to document information-security risks, assess likelihood and impact, prioritize risks, and outline control-testing and remediation activities.

Objectives

• Build and maintain a structured cybersecurity risk register.
• Assess risks using likelihood and impact scores.
• Prioritize risks based on calculated risk scores.
• Document a sample security-control assessment and its outcome.
• Recommend remediation actions and follow-up validation.
• Demonstrate how GRC concepts can be mapped to recognized frameworks.

Risk Scoring Method

Risk Score = Likelihood × Impact. Both likelihood and impact are scored from 1 (lowest) to 5 (highest). Severity bands used in this case study: **1–4 Low**, **5–9 Medium**, **10–16 High**, and **17–25 Critical**.

Risk Register Summary

Risk ID	Risk Title	Likelihood	Impact	Score	Severity
BR-001	Unauthorized Exposure of Customer PII	4	5	20	Critical
BR-002	Weak Password Security	4	4	16	High
BR-003	Ransomware Attack	3	5	15	High

Risk ID	Risk Title	Likelihood	Impact	Score	Severity
BR-004	Third-Party Vendor Security Risk	4	4	16	High
BR-005	Phishing and Social Engineering	4	5	20	Critical
BR-006	Inadequate Data Backup and Recovery	3	5	15	High
BR-007	Unauthorized Privileged Access	4	5	20	Critical
BR-008	Unpatched Systems and Vulnerabilities	4	5	20	Critical
BR-009	Insider Threat	3	5	15	High
BR-010	Business Continuity and Disaster Recovery Failure	3	5	15	High

Risk descriptions are maintained in the ServiceNow Cybersecurity Risk Register table. This summary lists the risk titles and scoring recorded for the portfolio exercise.

Sample Control Assessment – BR-001

Risk: Unauthorized Exposure of Customer PII
Control: Multi-Factor Authentication (MFA)
Control objective: Ensure MFA is enabled for all applicable user accounts to reduce the likelihood of unauthorized access to customer information.

Simulated test scenario: A sample of 10 user accounts was considered to check whether MFA was enforced.
Simulated result: 2 out of 10 sample accounts did not have MFA enabled.
Test outcome: Failed.
Risk score: 4 × 5 = 20 (Critical).

Evidence examples to request in a real assessment: MFA configuration or policy settings, user/account assignment reports, authentication logs, and documented exception approvals. These are examples only; no actual evidence was collected for this simulated project.

Recommended Remediation

Action ID	Remediation action	Suggested owner	Target / follow-up
RA-001	Enable MFA for all applicable accounts and investigate the two sample exceptions.	IT / Identity & Access Management team	Set a target date; validate configuration and retest after implementation.
RA-002	Document approved MFA exceptions, compensating controls, and periodic review requirements.	Information Security / GRC	Maintain an exception log and review it periodically.

Framework Reference

The project uses selected concepts from NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001:2022 as learning references for risk identification, access control, control evaluation, and remediation. This is an illustrative mapping exercise, not a formal compliance assessment, certification, or statement that the fictional organization conforms to either framework.

GRC Responsibilities Demonstrated

A GRC analyst typically supports risk identification and assessment, control documentation, evidence review, issue tracking, remediation follow-up, and reporting. Technical implementation—such as enabling MFA or changing system configurations—is generally performed by IT or security teams, while GRC helps define expectations, assess evidence, track gaps, and validate closure.

Tools & Deliverables

• ServiceNow Developer Instance: custom Cybersecurity Risk Register table and 10 sample risk records.
• GitHub: project documentation, risk register summary, sample control assessment, and remediation recommendations.
• Deliverable: documented risk-scoring approach and simulated MFA control-test scenario.

Suggested Resume Entry

Cybersecurity GRC Portfolio Project – Aarohan Bank Ltd. (Fictional Case Study)

- Built a ServiceNow-based cybersecurity risk register containing 10 simulated banking security risks.
- Applied a 5×5 likelihood-impact methodology to calculate risk scores and prioritize risks.
- Documented a simulated MFA control-assessment scenario, identified a sample control gap, and proposed remediation and retesting steps.
- Referenced NIST CSF 2.0 and ISO/IEC 27001:2022 concepts to structure risk and control documentation.

Portfolio integrity note: Describe this as a self-directed simulated project. Do not present the sample MFA result as a real audit, real customer-account test, or professional banking engagement.